

Report

TASK 2

PHISHING EMAIL DETECTION & AWARENESS SYSTEM

PREPARED FOR :
FUTURE INTERNS

PREPARED BY:
MONICA P

1.EXECUTIVE SUMMARY

This report fulfills the requirements of the Phishing Detection & Awareness System project. As part of this task, I have acted as a Security Analyst to bridge the gap between technical system defenses and human vulnerability.

About the Task: Phishing remains the most prevalent entry point for cyber attacks because it targets human psychology rather than system weaknesses. The core objective of this task was to:

- Analyze: Use forensic tools to dissect real-world phishing samples.
- Identify: Pinpoint "Red Flags" like spoofed domains, urgency-based language, and authentication failures.
- Classify: Categorize email threats based on technical risk (Safe vs. Phishing).
- Educate: Translate complex technical findings into a simple Awareness Document to prevent employees from sharing credentials or downloading infected files.

2.TECHNICAL ANALYSIS & TOOL OUTPUTS

Tool 1: Google Admin Toolbox (Messageheader Analysis)

Google Admin Toolbox - Messageheader						
Messageid	0107018fa93c57a5-0e72e18a-1525-41c5-82b-347b9e7027a5-000000@eu-central-1.amazonaws.com					
Created at:	7/31/2023, 5:27:35 AM GMT+5:30 (Delivered after 3 sec)					
From:	Binance <reply-support@binancewallet.s3.amazonaws.com> Using PHPMailer 6.1.5 (https://github.com/PHPMailer/PHPMailer)					
To:	phishing@out					
Subject:	[Binance] Withdraw Successful - 2023-07-30 51:51:51(UTC)					
SPF:	pass with IP Unknown Learn more					
DKIM:	pass with domain Unknown Learn more					
DMARC:	none Learn more					
#	Delay	From *	To *		Protocol	Time received
0	1 sec	MSQNAM12FT067-asp-nam12-prod-protection.outlook.com	MSQAP903CA0010-outlook.office365.com			7/31/2023, 5:27:36 AM GMT+5:30
1	2 sec	SUZPR19MB7507-namprd19-prod.outlook.com	MNQPR19MB6312-namprd19-prod.outlook.com			7/31/2023, 5:27:38 AM GMT+5:30

Figure 1: Forensic Authentication Snapshot

- SPF (Sender Policy Framework): PASS. The attacker utilized a legitimate Amazon SES IP to bypass basic reputation filters.
- DKIM (DomainKeys Identified Mail): PASS (Misaligned). While a signature was present, it belonged to the cloud relay, not the brand being impersonated.
- DMARC: NONE. The critical security gap. The lack of a DMARC policy on the sending domain allowed this unauthorized email to reach the inbox.
- Infrastructure: The X-Mailer was identified as PHPMailer 6.1.5, confirming automated script-based delivery.

TOOL 2: MXTOOLBOX (HEADER BREAKDOWN)

Figure Name: Advanced Alignment & Relay Verification

- DKIM Alignment Error: MXToolbox confirmed a mismatch between the "From" domain (auswestbc.com.au) and the signing domain (amazonses.com). This is a definitive indicator of Domain Hijacking.
- Sender Discrepancy: The attacker impersonated Binance using a hijacked Australian business domain.
- Relay Trace: Trace data shows the email originated from a server in Frankfurt, Germany, and was delivered with a high-speed relay typical of mass phishing campaigns.

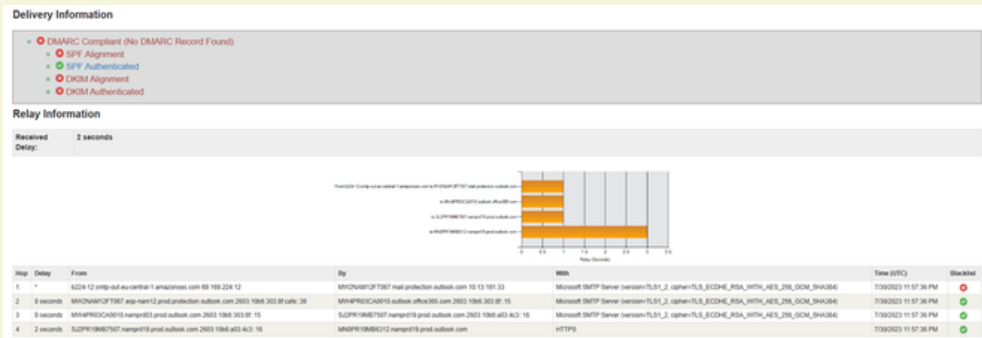


Figure 1: Email Delivery & Relay Path Analysis

Description: This image illustrates the "Delivery Information" and "Relay Information." It provides the hop-by-hop trace of the email as it traveled from the Amazon SES server in Frankfurt through Microsoft's protection layers, confirming a DMARC Non-Compliant status.

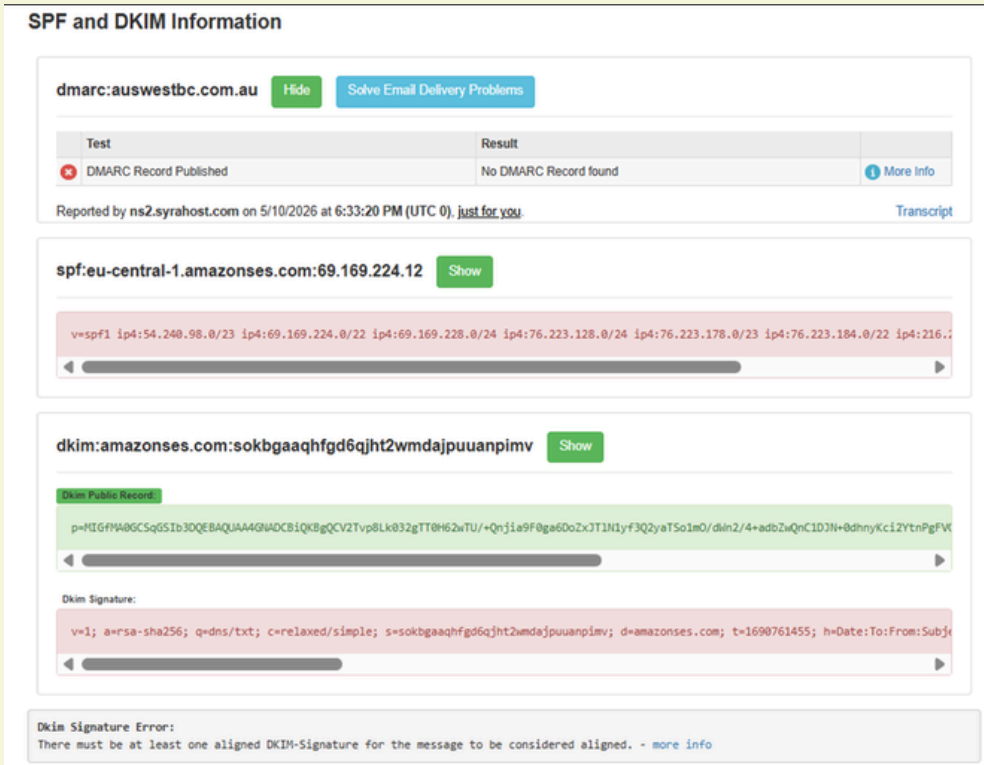


Figure 2: SPF/DKIM Authentication Breakdown

Description: This image shows the deep dive into the SPF and DKIM records. It explicitly identifies the DMARC Record Failure ("No DMARC Record found") and the DKIM Signature Error stating that the signature is not aligned with the message.

Headers Found	
Header Name	Header Value
Authentication-Results	spf=pass (sender IP is 69.169.224.12) smtp.mailfrom=eu-central-1.amazonaws.com; dkim=pass (signature was verified) header.d=amazonses.com; dmarc=none action=none header.from=auswestbc.com.au;
Received-SPF	Pass (protection.outlook.com: domain of eu-central-1.amazonaws.com designates 69.169.224.12 as permitted sender) receiver=protection.outlook.com; client-ip=69.169.224.12; helo=b224-12.smtp-out.eu-central-1.amazonaws.com; pr=C
X-IncomingTopHeaderMarker	OriginalChecksum:EE6B2CBEF31178356B9802CB33309BC117165DCFD0935F57EF26AC06F683C40;UpperCasedChecksum:F59442B20E693438C7A2AA7C1A1099511D357724E9FF854D40604E4426D296AD;SizeAsReceived:1259;Count:18
DKIM-Signature	v=1; a=rsa-sha256; q=dns/txt; c=relaxed/simple; s=sokbgaaqhf9d5qht2wmdajpuuanpimv; d=amazonses.com; t=1690761455; h=Date:To:From:Subject:Message-ID:MIME-Version:Content-Type:Content-Transfer-Encoding:Feedback-ID; bh=idXeaE6qbiUCB7iHaBEakK38hkFuY13Sfc64usxoa g=: b=dsGcXm48VCoqOghVT6WVmp;8G+PcSK040gleGDLwSahamHbblmkals+9JCJjnK.L4ccubvNPxH8A5kgdVU0ltLnLFAAdd5cdFTrPam5eFMSKZeHd9SdvLIEaTNbL4gimFx0 QVqLLJdCB3ubjZ7eTs3KwgW30D5M8AcV6dxMqjHA=
Date	Sun, 30 Jul 2023 23:57:35 +0000
To	phishing@pot
From	Binance <noreply-support@binancewallet.irs@auswestbc.com.au>
Subject	[Binance] Withdraw Successful - 2023-07-30 51:51:51(UTC)
Message-ID	<01070189a93c67a5-2d72e19a-1525-41c6-92cb-347e9e7f27a5-0000000@eu-central-1.amazonaws.com>
X-Mailer	PHPMailer 6.1.5 (https://github.com/PHPMailer/PHPMailer)
X-Attach-Flag	N
X-Business-Group	DS
X-Request-UUID	8FFC801A-9A4C-495C-9A7E-5056509B4733-QuotaEvent
Content-Type	text/html; charset=UTF-8
Content-Transfer-Encoding	base64
Feedback-ID	1.eu-central-1.z56IBL8by6m0FzCjOYMM5H22SK7KAwBASj074AKho= AmazonSES
X-SES-Outgoing	2023.07.30-69.169.224.12
X-IncomingHeaderCount	18
Return-Path	01070189a93c67a5-2d72e19a-1525-41c6-92cb-347e9e7f27a5-0000000@eu-central-1.amazonaws.com
X-MS-Exchange-Organization-ExpirationStartTime	30 Jul 2023 23:57:36.5069 (UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason	OriginalSubmit

Figure 1: MXToolbox Header Forensic Summary

Description: This image displays the raw "Headers Found" table from MXToolbox. It highlights the discrepancy between the "From" address (auswestbc.com.au) and the "Authentication-Results" showing a relay from amazonses.com. It also identifies the use of PHPMailer 6.1.5.

3. RISK CLASSIFICATION

Indicator	Technical Finding	Risk Level
Authentication	SPF Pass / DKIM Alignment Fail	Critical
Sender Domain	Hijacked Third-Party Domain (auswestbc.com.au)	High
Urgency Level	Financial Panic ("Withdrawal Successful")	High
Final Verdict	PHISHING (CONFIRMED)	Critical

4. HOW THE ATTACK WORKS (NON-TECHNICAL EXPLANATION)

Attackers use a "Panic and Pivot" strategy. By sending an email that looks like a bank or crypto alert (The Bait), they cause you to worry about your money. When you click the link to "fix" the problem, you are taken to a fake website (The Hook) that looks exactly like the real thing. Once you type in your password or OTP, the attacker captures it instantly.

5. PREVENTION & AWARENESS GUIDELINES

1. The DO'S (Best Practices)

- **Verify the Domain:** Check if the email ends in the official company domain (e.g., @binance.com).
- **Hover Before Clicking:** Hover over any link or button to see the actual destination URL in the corner of your browser.
- **Enable MFA:** Use app-based Multi-Factor Authentication so your account remains safe even if your password is stolen.

2. The DON'TS (Red Flags)

- **Don't Trust "Pass" Status:** An email can pass basic security checks and still be a fraud.
- **Don't Act Under Pressure:** Legitimate companies will rarely give you a 24-hour ultimatum to verify your details.
- **Don't Download Attachments:** Never open .zip or .exe files from unexpected senders.

6. CONCLUSION

This task demonstrates that technical tools like Google Admin Toolbox and MXToolbox are essential for verifying what the naked eye cannot see. While attackers are becoming more sophisticated by using trusted cloud relays, a combination of Technical Analysis and Employee Awareness creates a resilient defense against phishing attacks.